VIRTUAL GOLD × CMU CAPSTONE · CLIENT MEETING

Progress since Oct 19, and what we need from you

The service now runs on its own detection components, the model results improved, the test set is built, and the encryption design is implemented. Two parts are proposals we would like your view on: a revised tier table and the encryption modes. To finish Phase 1 on time we also need your answers on acceptable leak rates and where the service will run.

MEETING
Monday 2026-10-26, 18:00 ET

PHASE
Phase 1 starts today (Oct 26–Nov 8)

01 Where we are

Milestones from the midterm deck. Green is done, gold is in progress.

- Oct 5 Midterm presentation
- Oct 19 API contract 0.4.2 and service skeleton, with monitoring dashboard
- Oct 23 Privacy components in the service: rules, Presidio, merging, scoring, placeholders
- Oct 26 Conversation keys and both encryption modes in the service (off by default, proposal in section 07)
- Nov 1 End-to-end pipeline with the failure path (model prompts still being wired in)
- Nov 8 Dashboard and load-test results; Phase 1 ends
- Nov 2–15 Phase 2: VG08 integration; contract freeze Nov 15
- Nov 22 Code freeze (soft freeze Nov 18)
- Nov 30 Final presentation

02 Progress since Oct 19

Four workstreams at a glance. Details for each follow in sections 03 to 07.

DETECTION · YUDI
RULES AND PRESIDIO

8 fixes

from testing on 1,000 rows of an external labelled set (ai4privacy)

- Email 100% found; dates of birth 83%, phone 75%, government IDs 69%, names 68%
- Fewer false positives on short codes, fiscal periods and order numbers
- A revised tier table (policy 0.1.3) for your review

MODEL · ANMOL
MODEL EVALUATION

7.4%

of private characters left unmasked, best configuration (Oct 19 best: 16.2%)

- Qwen 3.8 27B + GLiNER, sized for one 24–48 GB GPU; 9 of 10 confidential facts caught; 2.4 s per email
- GPT-OSS 120B masks the least public text (5–12%) but leaks more
- No-LLM fallback (rules + Presidio + GLiNER): 29.4% in 0.11 s
- Tested on hosted open-weight model APIs; not yet deployed in a VPC. 15 emails, 4 of 15 business areas

EVALUATION · KARINA
TEST SET

1,054

labelled items in 100 fictional executive emails

- Each email is also a valid service request, so service output scores with no conversion
- Rules alone catch 66% of items; the model has to close the gap
- Labelled against the current tier table (policy 0.1.1)

SERVICE · ZHEXUAN
CONVERSATION KEYS AND ENCRYPTION

2 modes

each conversation gets its own key; both modes implemented

- `mapping` : originals stored encrypted on the server
- `aes_siv` : the encrypted original travels inside the token; no mapping stored
- Restore needs only the text; closing a conversation invalidates its tokens

03 Detection: rules and Presidio

Yudi · Oct 25

We tested the fixed-format detectors on data, fixed the worst errors, and tested again. Context cases (loose address parts, company versus person, business secrets, health) are left to the model rather than hand-written rules.

HOW WE TESTED

- Dataset: ai4privacy pii-masking-400k, 1,000 English validation rows (synthetic, US and UK). Kept on our machines; its licence bars redistribution.
- 16 of its 17 labels map to our categories. Only types the tier table assigns to rules or Presidio are scored.
- A labelled item counts as found if any detected span overlaps it.

RESULTS AFTER THE FIXES (RULES AND PRESIDIO COMBINED)

CATEGORY	FOUND	RIGHT CATEGORY	PRECISION
EMAIL_PERSONAL	100%	100%	100%
DATE (birth dates)	83%	83%	–
PHONE_PERSONAL	75%	64%	60%
CITY	74%	60%	43%
GOV_ID	69%	36%	63%
PERSON	68%	62%	54%
ACCOUNT_NUMBER	53%	42%	62%
ADDRESS_HOME	40%	4%	–
CARD_NUMBER	25%	8%	18%

- Precision is understated: the dataset leaves IMEIs, passports, crypto wallets and company names unlabelled, so correct hits on them count as errors.
- Addresses: the dataset labels house number, street and ZIP separately, while our rule looks for a full US address. These parts are left to the model.
- Cards: the dataset's card numbers are random (only 10% pass the checksum), so this row does not measure real cards.
- Most of the recall comes from Presidio. Rules alone: email 100%, government IDs 32%, phone 28%.

EIGHT FIXES

#	PROBLEM	FIX
1	Short codes like `x4521`, `Q3` taken as government IDs (High)	Keep only with context or 7+ characters
2	"Email", "Reach" at sentence start taken as names	Drop single listed words at sentence start
3	`Q3` taken as a place; "age 42" as a date	Drop fiscal periods; retype to AGE
4	Codes like `X501` taken as phone extensions	Stricter extension rule (rules phone precision 89% → 100%)
5	No rules for addresses, ages or sign-off names	Added US address, age and "Thanks, Name" rules
6	Order numbers passing the checksum taken as cards	Card numbers must start with 2–6
7	Long digit strings taken as dates (Low)	Retype to ACCOUNT_NUMBER (High); Low-tier misses 14 → 2
8	"Bank account" too narrow	Renamed ACCOUNT_NUMBER, covering bank, brokerage and client accounts (right category 23% → 42%)

STILL OPEN

- Addresses split into parts are missed or tagged as city or date; left to the model.
- Some SSNs and tax IDs tagged as phone numbers (High drops to Medium); document numbers like `FILE-201307-4379` tagged as phone.
- Company names tagged as people.
- Thresholds will be tuned once real emails and the model path are in.

04 Proposed tier table (policy 0.1.3)

`for your review: Q1` `Yudi`

22 categories in 4 tiers. The tiers and categories were confirmed at our last meeting; Yudi proposes three changes because they matched the test data more accurately. The changes are ready and will be merged once you confirm. The full table is also in the attached document (`tier-table-client-review-en.docx`).

CHANGES FROM THE CURRENT TABLE (0.1.1)

- **BANK_ACCOUNT → ACCOUNT_NUMBER**: now covers bank, brokerage and client accounts, IBANs, crypto wallets and other long numeric IDs.
- **New ADDRESS_PUBLIC** (Public): published office and business addresses, so they are not treated as home addresses.
- **Public threshold 0.5 → 0.8**: a public-looking item is redacted only when the model is fairly sure it is private. Public contacts are meant to be shared; the risk is a personal number mistaken for a public one.

HOW EACH TIER IS HANDLED

The local model gives each item a score: the probability that it is private. The tier sets the cut-off.

TIER	RULE	REDACTED WHEN
High	Redact	Score ≥ 0.2, even when the model is fairly unsure
Medium	Redact	Score ≥ 0.5
Low	Keep, unless combined	3 or more different Low categories in the same field (e.g. city + employer + age)
Public	Keep if confidently public	Score ≥ 0.8

Always redacted, whatever the score: your term list, words a request marks as forbidden, and items the model cannot classify. All thresholds are starting values, tuned later on the test set.

CATEGORIES

Three detectors run on every email and their results are merged: the local model, pattern rules and Presidio (an open-source PII toolkit).

CATEGORY	TIER	EXAMPLES
`GOV_ID`	High	SSN, passport, driver's licence, ITIN
`CREDENTIAL`	High	Passwords, API keys, access tokens

CATEGORY	TIER	EXAMPLES
`CARD_NUMBER`	High	Payment card numbers
`ACCOUNT_NUMBER`	High	Bank, brokerage and client account numbers, IBAN, crypto wallets, other long numeric IDs
`HEALTH`	High	Diagnoses, treatments, medical leave
`BUSINESS_CONFIDENTIAL`	High	Unreleased financials, deal terms, legal matters
`CODENAME`	High	Project and deal code names, counterparties
`DEMOGRAPHIC`	High	Nationality, religion, political affiliation
`PERSON`	Medium	Names of people
`PHONE_PERSONAL`	Medium	Personal phone numbers and extensions
`EMAIL_PERSONAL`	Medium	Personal email addresses
`ADDRESS_HOME`	Medium	Street addresses, PO boxes
`NETWORK_ID`	Medium	IP and MAC addresses
`AMOUNT`	Medium	Money amounts ($4.2M, USD 500k)
`CITY`	Low	Cities, countries
`DATE`	Low	Dates and times
`ORG`	Low	Company and organisation names
`AGE`	Low	"age 42", "42-year-old"
`GENDER`	Low	Gender
`PHONE_PUBLIC`	Public	Company switchboard, support lines
`EMAIL_PUBLIC`	Public	info@, support@ mailboxes
`ADDRESS_PUBLIC`	Public	Publicly listed office and business addresses

Personal-data tiers follow NIST SP 800-122 impact levels; health and demographic data are High per GDPR Art. 9.

05 Model evaluation

Anmol · Oct 25

After fixing six defects in the test harness, we ran 9 new configurations on the same 15 development emails used on Oct 19. All runs used hosted open-weight model APIs; the service is not yet deployed in a VPC. GPU sizes describe what each model would need when self-hosted. We walk through the full report (`briefing-vpc-model-evaluation-en.md`) in the meeting.

MAIN RESULTS

CONFIGURATION	GPU WHEN SELF-HOSTED	PRIVATE TEXT LEAKED	PUBLIC TEXT OVER-MASKED	CONFIDENTIAL FACTS CAUGHT	SECONDS PER EMAIL
Rules + Presidio (no model)	none	42.8%	2.3%	0 of 10	0.00
Rules + Presidio + GLiNER (no LLM)	under 1 GB	29.4%	6.6%	0 of 10	0.11
Llama 3.3 70B (Oct 19 reference)	80 GB	16.2%	18.5%	6 of 10	40.8
Qwen 3.8 27B + GLiNER (best)	24–48 GB	**7.4%**	21.7%	9 of 10	2.4
Qwen 3.8 27B	24–48 GB	11.7%	18.3%	9 of 10	1.8
Qwen 3.8 27B, then Safeguard 20B as checker	24–48 GB	14.0%	14.7%	8 of 10	1.8
GPT-OSS 120B	80 GB	22.9%	11.5%	4 of 10	2.3
GPT-OSS 120B, single pass	80 GB	27.0%	5.4%	3 of 10	1.6

- The best configuration halves the Oct 19 leak rate and fits on one 24–48 GB GPU. Its cost is more over-masking of public text.
- GPT-OSS 120B over-masks least, but leaks more and needs an 80 GB GPU.
- The no-LLM setup (rules + Presidio + GLiNER) is a candidate fallback when the model is unavailable.
- Limits: 15 emails covering 4 of 15 business areas; speeds are from hosted APIs, not your hardware; measured with an earlier version of the tier rules (see Q2).

06 Test set: 100 emails, 1,054 labelled items

`Karina` `baseline v1.1`

The same 100 fictional executive emails as before, rebuilt so the service can be scored on them directly. This also answers Aarvin's question at the midterm about how we can trust labels an LLM produced: an LLM proposed the labels, and a person checks every one.

WHAT CHANGED

- **Each email is a service request.** It goes straight into the API, and each item carries the service's own field positions, category and tier, so results score with no conversion.
- **Every item is marked redact or keep.** 1,054 items: 1,006 to redact, 48 to keep. 984 agree with the first version, 15 moved to keep (e.g. `no-reply@` mailboxes, the company's public office address), and 55 were added (mostly names and amounts inside confidential facts).
- **Labelled against the current tier table (policy 0.1.1).** If you confirm 0.1.3, we update the categories.
- **Split:** 60 emails for development, 40 held back for one final test.

FIRST SCORES

DETECTOR	ITEMS CAUGHT	EMAILS THAT LEAK SOMETHING
Simple regular expressions (floor)	40%	96%
The service's rules alone	66%	87%

Both rows use the rules currently in the service: they do not include the fixes in section 03, and they run without Presidio or the model. Yudi's numbers in section 03 come from a different, external dataset, so the two sections do not compare directly.

Rules catch every email address and 79% of names, but no bank accounts, code names, health details or ID numbers. The model has to close that gap.

WHAT THE TEST SET TELLS US ABOUT THE TIER TABLE

- **86 items that should be redacted sit in the Low tier**: 67 company names, 12 cities, 6 dates, 1 age. Because a Low item seen alone is kept, the service would let all 86 through, even when the model is sure they are private. The worst are deal counterparties and dates of birth.
- **39 ID numbers** (case, medical record and order numbers) have no category yet. They are redacted by default, so nothing leaks, but public ones like filing numbers get over-masked.
- Only 4 of the 100 emails are fully clean; the other 96 contain something to redact.

These feed into Q1.

07 Encryption proposal: conversation keys, two modes

`for your view: Q5` `Zhexuan`

A second version of the API (v2) alongside the current one. Both modes are implemented and in the service, switched off by default. The current API is unchanged. We would like your view before we make it the default.

MAPPING · DEFAULT
REFERENCE TOKEN + ENCRYPTED MAPPING

- The token points to a server-side record; the original is encrypted before it is stored
- Deleting a group's mappings invalidates its tokens
- Needs persistent storage for mappings and keys

AES_SIV · ALTERNATIVE
THE TOKEN IS THE ENCRYPTED ORIGINAL

- No original-value mapping is stored on the server
- Same value and type in one conversation give the same token
- Tokens grow with the length of the original; models must pass them through exactly

HOW IT WORKS

1. **Redact.** Your app sends the text with its own conversation ID (`group_id`). The first request creates a random key for that conversation; later requests reuse it.
2. **Agent.** Agents pass the redacted message on unchanged. They never handle keys.
3. **Restore.** Send the text back. Each token tells the service which conversation it belongs to; the service checks permissions and expiry, then restores.
4. **Close.** When the conversation ends, close it with the same ID. Its tokens can no longer be restored.

KEY PROTECTION

Each conversation has its own random key, wrapped by a master key; separate keys are derived for each purpose. Callers never receive keys. A conversation lives up to 24 hours by default. Service copies share state through Redis.

WHAT A PLACEHOLDER LOOKS LIKE

	CURRENT API	V2 PROPOSAL
Placeholder	`[PERSON_1]`, short, shows the category	`[VG:2:…]`, longer, grows with the original
Restore needs	The request ID	Only the text
State kept	Per request	Per conversation, up to 24 hours
Tested with real models	Yes, in the model evaluation	Not yet

NEXT FOR V2

- Test whether real models keep the long tokens exactly.
- Fix a check that mistakes some ordinary bracketed text for a token.
- The technical documents are in our repository under `docs/api/`; we can share copies.

08 What we need from you

In order of what blocks us soonest.

Q1 Tier table: the 0.1.3 changes and what the test set found

`blocks Phase 1 scoring` `D49` `section 04`

The tiers and categories stand as confirmed at our last meeting. Two things are new since then: the three changes in 0.1.3, and some cases the test set surfaced.

- Do you accept the three changes in 0.1.3 (ACCOUNT_NUMBER, ADDRESS_PUBLIC, Public at 0.8)?
- Dates of birth fall under DATE (Low) today. Should they be their own category, at Medium or High?

- Deal counterparties are company names, so they fall in Low today. Which tier should they be in?
- ID numbers (case, medical record, order numbers): which tier?
- When the model is sure a Low item is private, should it still be kept when it appears alone?

Q2 What leak rate is acceptable per tier?

`before the final test` `D70`

This sets the final thresholds. We will run the 40 held-back emails once, after freezing the pipeline. Before that we need targets: the share of private text that may leak in each tier, how much over-masking of public text is tolerable, seconds per email, and what should happen when the model fails.

The model figures in section 05 were measured with an earlier version of the tier rules. We will re-run them under the tier table you confirm, so they compare directly with these targets.

Q3 Where will the service run?

`D51`

The best model needs one 24–48 GB GPU; the next tier needs 80 GB. Will it run in your private cloud, and when can we test there? Until then we test on hosted open-weight models, as agreed on Sep 28.

Q4 Documents as input, and routing

`A15` `A14` `before Nov 15 freeze`

The SOW says "English text and documents". The service takes email today. Which document types matter for Phase 1 (contracts, tables, memos)? And for routing: should the service return a "keep local" status for a whole request, or does VG08 decide from the redacted items?

Q5 Encryption mode and placeholders

`A18` `section 07` `before Nov 15 freeze`

- Should the service never store original values (`aes_siv`), or is an encrypted server-side mapping acceptable (`mapping`)?
- Do VG08 and your agents need to see the category of what was removed (`[PERSON_1]`), or is an opaque token (`[VG:2:…]`) fine?
- Will VG08 and your agents pass placeholders through unchanged?
- Can VG08 send its own conversation ID with each request, and close the conversation when it ends? Is a 24-hour maximum right?

Q6 VG08 access and the SOW

`D52` `E68`

Phase 2 starts Nov 2: when can we connect to VG08? And the Scope of Work given at the midterm is not signed yet; is anything holding it up?

09 Next two weeks

- Wire the model prompts into the service; first end-to-end run by Nov 1
- Apply the tier table you confirm, update the test set's categories, and score the service on the 60 development emails
- Run the rules with the section 03 fixes, plus Presidio, on the 100 emails
- Re-run the model evaluation under that tier table; extend from 15 to 60 emails
- Encryption: test long tokens with real models, and fix the token check

Materials: `briefing-vpc-model-evaluation-en.md` (Anmol), `briefing-rules-presidio-eval-en.html` and `tier-table-client-review-en.docx` (Yudi), `briefing-encryption-api-en.html` (Zhexuan), test set README (Karina).